



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



ShinyHunters Threat Actor Profile

Threat Actor Profile

Classification	TLP:CLEAR
Published	2026-07-30
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Actor Profile

TLP:CLEAR | Lost Boys Cyber | ShinyHunters Threat Actor Profile - Threat Actor Profile

Published: 2026-07-30 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review and Confidence
4. Threat Actor Overview and Narrative
 - 4.1. Identity and Aliases
 - 4.2. Motivation and Business Model
 - 4.3. Actor Composition and Culture
 - 4.4. Evolution by Era
 - 4.5. How ShinyHunters Thinks
 - 4.6. Why This Actor Matters
 - 4.7. Analyst Bottom Line
5. Tactics, Techniques, and Procedures
6. Campaign and Tradecraft Deep Dive
 - 6.1. Snowflake Customer Data-Theft Cluster (UNC5537)
 - 6.2. Salesforce Vishing and OAuth Abuse (UNC6040 / UNC6240)
 - 6.3. Expanded SaaS Targeting and Data Discovery
7. Infrastructure and Indicators
8. Victimology and Targeting
9. Detection Engineering
 - 9.1. Detection Summary
 - 9.2. Sigma: Salesforce Suspicious Connected App Authorization
 - 9.3. Sigma: Snowflake Temporary Stage Export Sequence
 - 9.4. KQL: Entra ID MFA Enrollment or Reset Followed by Risky SaaS Sign-In
 - 9.5. KQL: M365 Sensitive Document Searches After Identity Change
 - 9.6. KQL: Salesforce Bulk Export Spike Correlated With New OAuth Consent
 - 9.7. SPL: Snowflake Exfiltration Commands
 - 9.8. YARA: Data Loader-Like Python Export Script (Repository / Endpoint Triage)
10. Threat Hunting
 - 10.1. Hunt 1: OAuth Consent to High-Risk SaaS App Followed by Data Access
 - 10.2. Hunt 2: Snowflake Data Staging and Exfiltration Sequence
 - 10.3. Hunt 3: Help-Desk Reset Pattern Across Multiple Users
 - 10.4. Hunt 4: Deletion of MFA and Security Notification Emails
 - 10.5. Hunt 5: Sensitive-Term Searches in Collaboration Platforms
11. Risk Assessment
12. Recommendations
13. Incident Response Playbook Addendum
14. References

ShinyHunters Threat Actor Profile

1. Executive Summary

Field	Assessment
Actor	ShinyHunters, a financially motivated cybercrime and extortion brand active since at least 2019
Current operating model	Data theft, cloud/SaaS credential abuse, OAuth/connected-app abuse, marketplace monetization, public extortion, and occasional collaboration or brand overlap with adjacent English-speaking cybercrime communities
Key overlaps	UNC6040 and UNC6240 in Salesforce-focused intrusions/extortion; UNC5537 in Snowflake customer data theft; BreachForums administration and data-leak marketplace activity; reported overlap or loose alliance with Scattered Spider/LAPSUS\$-adjacent communities in some 2025 reporting
Primary defensive priority	Treat identity, SaaS administration, CRM/data-warehouse export paths, and third-party integration approval workflows as the actor's main attack surface
Analyst confidence	High for the SaaS/cloud data-theft tradecraft and defensive controls; Medium for exact membership boundaries because public reporting mixes actor brand, intrusion clusters, forum personas, affiliates, and copycat claims

ShinyHunters is best understood as a cybercriminal brand and operating network built around the theft, sale, and extortion of large data sets. Earlier activity emphasized database dumps, credential markets, public breach claims, and cybercrime-forum reputation. By 2024-2026, the brand became strongly associated with high-impact SaaS and cloud data-theft campaigns, especially Snowflake customer compromises and Salesforce-focused vishing/OAuth abuse. The center of gravity is not endpoint malware. It is access to business data at scale: CRM records, customer data, data warehouses, Slack or collaboration content, documents containing confidential terms, and credentials or tokens that allow repeatable exfiltration.

The actor's value proposition in the criminal ecosystem is speed and pressure. ShinyHunters-branded operations convert valid credentials, OAuth grants, SaaS permissions, and cloud data access into large searchable data sets that can be sold, leaked, or used for direct extortion. Google Threat Intelligence Group (GTIG) reported that UNC6240 extortion activity following UNC6040 Salesforce intrusions involved calls or emails demanding bitcoin payment within 72 hours and consistently claimed the ShinyHunters name. Mandiant separately assessed that UNC5537 used stolen Snowflake customer credentials, many harvested by info stealers years earlier, to access customer instances, stage data, and exfiltrate records for sale or extortion.

For defenders, ShinyHunters is a warning that mature perimeter and EDR programs can still fail if identity recovery, SaaS application authorization, cloud data export paths, service accounts, contractors, and long-lived credentials are weak. The most durable detections are therefore not hash-based. They are behavior analytics across SSO, MFA lifecycle events, OAuth/connected-app approvals, Salesforce Data Loader activity, Snowflake SQL export commands, anomalous cloud storage transfers, deletion of MFA notification emails, and post-compromise searches for sensitive terms such as confidential, internal, proposal, salesforce, vpn, or poc.

2. Intelligence Requirements

Requirement	Current Answer	Confidence	Defensive Decision
What is ShinyHunters?	A financially motivated cybercrime/extortion brand associated with data theft,	High	Frame response around data exposure and SaaS identity compromise, not only

	breach forums, marketplace leaks, and cloud/SaaS data theft campaigns.		ransomware.
Is ShinyHunters the same as UNC6040/UNC6240/UNC5537 ?	Not exactly. GTIG tracks Salesforce intrusion activity as UNC6040 and subsequent extortion as UNC6240, with extortion communications claiming ShinyHunters. Mandiant tracks Snowflake customer compromises as UNC5537. These labels overlap with ShinyHunters branding but should not be treated as perfectly identical legal entities.	Medium-High	Use cluster-specific detections while briefing leadership under the ShinyHunters brand where relevant.
What initial access paths matter most?	Stolen credentials from infostealer logs, missing MFA, weak network allow lists, vishing, credential harvesting, MFA-device enrollment abuse, OAuth/connected-app authorization, contractor and third-party access.	High	Prioritize phishing-resistant MFA, help-desk verification, token revocation, SaaS app governance, credential hygiene, and managed-device requirements.
Which data stores are at highest risk?	Salesforce, Snowflake, Microsoft 365, Okta-linked apps, Google Workspace, Slack/collaboration stores, cloud storage, CRM exports, data warehouses, support/ticket systems, and documents containing internal or confidential business data.	High	Instrument SaaS audit logs and data export monitoring before relying on endpoint-only telemetry.
What is the most likely monetization path?	Direct extortion, public leak pressure, underground sale of database dumps, reputational pressure through breach forums/data leak sites, and reuse of stolen records for downstream fraud.	High	Prepare extortion playbooks, legal/comms workflows, data impact analysis, and leak monitoring.

3. Source Review and Confidence

Source	Contribution	Confidence	Notes
Google Cloud / Mandiant UNC5537 Snowflake analysis, June 2024	Primary evidence for Snowflake customer compromises using stolen credentials, lack of MFA, network allow-list gaps, SnowSQL/SnowSight/DBEaver /FROSTBITE usage, SQL staging and GET exfiltration.	High	Most authoritative baseline for Snowflake-specific TTPs.

Google Cloud / GTIG voice-phishing-to-data-extortion report, June 2025	Primary evidence for UNC6040 Salesforce vishing, malicious Data Loader connected-app authorization, Okta phishing panels, Mullvad/TOR use, UNC6240 extortion claiming ShinyHunters.	High	Separates intrusion cluster from extortion cluster.
Google Cloud / Mandiant UNC6040 hardening recommendations, September 2025	Defensive guidance for application integration policies, Salesforce connected-app controls, IdP/SaaS monitoring, help-desk process controls, and rapid containment.	High	Used for recommendations and detection priorities.
Google Cloud / Mandiant proactive defense against ShinyHunters-branded SaaS data theft, January 2026	Current synthesis of ShinyHunters-branded SaaS data theft: vishing, victim-branded credential harvesting, SSO compromise, MFA device enrollment, non-human identity risk, platform-specific hardening.	High	Provides high-confidence defensive control mapping.
Google Cloud / Mandiant expansion of ShinyHunters-branded SaaS data theft, January 2026	Current campaign expansion detail including document/SharePoint search terms, Slack targeting claims, detection examples, and SaaS-focused exfiltration patterns.	High	Supports hunt hypotheses for sensitive-term searches and MFA lifecycle patterns.
Salesforce guidance on protecting environments from social engineering and malicious connected apps	Vendor-side CRM hardening and monitoring baseline.	High	Used for Salesforce control recommendations.
Snowflake hardening and hunting guidance	Vendor-side data warehouse baseline for MFA, network policies, session policies, user monitoring, and SQL query investigation.	High	Used for Snowflake analytics.
CISA Scattered Spider advisory AA23-320A	Context for adjacent vishing/help-desk identity tradecraft in English-speaking cybercrime communities.	Medium	Used only for overlap/context, not to conflate Scattered Spider with ShinyHunters.
Sophos and mainstream reporting on BreachForums/ShinyHunters arrests	Law-enforcement and marketplace context.	Medium	Useful for ecosystem view; exact membership impact remains uncertain.
Krebs, BleepingComputer, The Register, Computer Weekly, and comparable public reporting	Victimology and public disclosure context for Salesforce/extortion waves.	Medium	Corroborating secondary sources; individual victim claims should be verified before client-specific statements.

Confidence notes: This profile treats ShinyHunters as a brand and threat-activity ecosystem rather than a single static crew. Attribution is high-confidence where GTIG/Mandiant name a tracked cluster and describe observed TTPs. Attribution is medium-confidence where public sources state that a campaign was claimed by ShinyHunters, branded as ShinyHunters, or linked through Telegram/forum personas. This matters operationally: defenders should not wait for perfect naming alignment before deploying controls against the shared behaviors.

4. Threat Actor Overview and Narrative

4.1. Identity and Aliases

ShinyHunters emerged around 2019 as a cybercriminal name associated with large database thefts, sale of stolen records, and activity on English-language cybercrime forums. The name became especially visible through data-breach marketplaces and BreachForums-linked activity. By 2024-2026, the brand increasingly represented a SaaS and cloud data-extortion operating model rather than a simple database-dump persona.

Commonly associated names and labels include ShinyHunters, ShinyCorp, ShinyHunters-branded extortion, UNC6240 for extortion following Salesforce intrusions, UNC6040 for Salesforce-focused vishing/OAuth intrusions, UNC5537 for Snowflake customer compromises, and overlapping references to BreachForums administration or related personas. Some public reporting describes loose operational overlap with Scattered Spider, LAPSUS\$-adjacent communities, and broader English-speaking cybercrime subcultures. Those relationships should be treated as overlapping communities and collaboration surfaces, not as proof that every named campaign is operated by the same individuals.

4.2. Motivation and Business Model

ShinyHunters is financially motivated. The actor monetizes data exposure through multiple channels:

Monetization Path	Description	Defender Impact
Underground sale	Stolen databases are advertised or sold on cybercrime forums and private channels.	Organizations need dark-web monitoring, breach impact analysis, and customer-notification readiness.
Direct extortion	Victims receive calls or emails demanding payment to prevent publication or sale.	Crisis communications, legal, executive, and security teams must coordinate quickly.
Data leak pressure	A data leak site or public persona increases reputational pressure.	Public claims may precede full verification; response should separate claim validation from containment.
Credential reuse	Stolen records, tokens, and credentials enable downstream account takeover or fraud.	Password resets alone are insufficient; token/session revocation and fraud controls are needed.
Access resale/collaboration	Access or data may be handed to another actor for monetization.	Incident scoping must include delayed extortion months after initial theft.

The actor's core business model rewards fast identification of exportable data and fast application of pressure. That creates a characteristic pattern: obtain valid access, enumerate SaaS data, export records, delay or hand off extortion, then apply public pressure using the ShinyHunters brand.

4.3. Actor Composition and Culture

Public reporting often frames ShinyHunters in the context of cybercrime forums, Telegram channels, and English-speaking criminal communities. The culture is reputation-driven: public claims, breach listings, countdowns, victim naming, and marketplace credibility all matter. This produces a different operational personality than stealth-first espionage. ShinyHunters-branded activity frequently seeks visibility after data has been stolen because visibility increases leverage.

Law-enforcement actions against BreachForums-linked personnel and alleged ShinyHunters-associated individuals show that parts of the ecosystem are vulnerable to arrest and infrastructure disruption. However, arrests do not necessarily end the threat.

The brand, tradecraft, data, and community relationships can persist through new handles, successor forums, mirrors, Telegram channels, and copycat extortion.

4.4. Evolution by Era

Era	Operational Emphasis	Representative Activity	Defensive Meaning
2019-2021	Database dumps and credential/data sales	Public breach claims and marketplace listings	Monitor exposed data and credentials; assume old credentials may remain useful.
2022-2023	Forum reputation and breach-market infrastructure	BreachForums/RaidForums successor ecosystem	Marketplace disruption changes channels, not necessarily actor behavior.
2024	Snowflake customer data theft	UNC5537 uses stolen credentials, no MFA, no allow lists, DBEaver/FROSTBITE/SnowSQL, SQL staging and GET exfiltration	Data warehouses become direct extortion surfaces.
2025	Salesforce vishing and malicious connected apps	UNC6040 tricks users into authorizing Data Loader-like apps; UNC6240 extorts and claims ShinyHunters	SaaS OAuth approval and help-desk workflows become initial-access control points.
2026	Broader ShinyHunters-branded SaaS targeting	Reports describe victim-branded credential harvesting, unauthorized MFA device enrollment, Slack/SharePoint/document search targeting, non-human identity abuse	Defenders need cross-SaaS correlation, app governance, and behavior-based detection.

4.5. How ShinyHunters Thinks

ShinyHunters does not need to compromise every layer of an enterprise. It looks for the shortest path to business data that can be sold or weaponized. The actor's mental model is likely:

- Which login, token, or OAuth grant gives access to the largest data store?
- Which employee can be convinced by phone to approve the connection or MFA change?
- Which SaaS platform exports the cleanest, highest-value records?
- Which search terms reveal sensitive documents quickly?
- Which victim can be pressured by public claims, customer exposure, or regulatory fear?
- Which marketplace or leak channel gives the actor credibility and bargaining power?

This mindset makes conventional endpoint-only defense insufficient. Many intrusions may generate few malware artifacts. The evidence is in identity logs, app authorization logs, SaaS audit trails, data export records, network egress, and support-desk tickets.

4.6. Why This Actor Matters

ShinyHunters matters because it demonstrates the industrialization of SaaS data theft. Enterprise security programs often invest heavily in endpoint detection and network perimeter controls while leaving cloud data warehouses, CRM exports, OAuth approvals, and contractor access under-instrumented. ShinyHunters-branded campaigns turn those gaps into board-level events without needing a destructive payload. For organizations with significant customer data, regulated PII, sales pipelines, authentication data, or high-profile brand exposure, the actor can create ransomware-like impact through data theft alone.

4.7. Analyst Bottom Line

ShinyHunters should be briefed to leadership as a cloud/SaaS extortion actor whose stable capability is data monetization, not a single malware family. The most important defensive move is to reduce the number of identities and integrations that can export sensitive data without phishing-resistant MFA, managed-device posture, admin approval, network restrictions, and behavioral monitoring. If an organization can quickly answer who approved a connected app, who enrolled a new MFA factor, who exported CRM tables, who created a temporary Snowflake stage, and who searched for confidential documents, it is much better positioned against this actor.

5. Tactics, Techniques, and Procedures

ATT&CK Tactic	Technique	ShinyHunters-Branded Behavior	Detection Focus
Reconnaissance	T1593 Search Open Websites/Domains; T1591 Gather Victim Org Information	Collection of employee, help-desk, vendor, and SaaS process details to support vishing and convincing pretexts.	Repeated calls to support, suspicious access to public docs, suspicious domain lookalikes.
Resource Development	T1583 Infrastructure; T1586 Accounts	Phishing panels, victim-branded credential sites, webmail or compromised accounts for malicious app registration, VPN/TOR infrastructure.	Newly observed IdP lookalike domains, low-reputation OAuth app publishers, VPN/TOR access patterns.
Initial Access	T1078 Valid Accounts; T1566 Phishing; T1199 Trusted Relationship	Use of stolen credentials, contractor credentials, vishing, credential harvesting, and third-party/vendor impersonation.	Impossible travel, high-risk sign-ins, unmanaged device access, help-desk reset followed by login.
Persistence	T1098 Account Manipulation; T1550 Use Alternate Authentication Material	Unauthorized MFA enrollment, OAuth token grants, long-lived API keys, non-human identity abuse.	MFA lifecycle events, new OAuth consent grants, new service-account keys, suspicious token usage.
Privilege Escalation	T1098 Account Manipulation; T1548 Abuse Elevation Control Mechanism	Manipulation of identity or SaaS permissions after valid access.	Privileged role assignment, app permission expansion, Salesforce profile/permission-set changes.
Defense Evasion	T1070 Indicator Removal; T1562 Impair Defenses	Deletion of MFA notification emails, use of legitimate tools, use of TOR/VPN, reliance on valid credentials.	Email deletion rules, security-alert deletion, login from anonymizers, anomalous legitimate tool use.
Credential Access	T1555 Credentials from Password Stores; T1528 Steal Application Access Token	Infostealer-derived credentials, SSO credential harvesting, OAuth grants, access tokens.	Credential exposure monitoring, new OAuth grants, anomalous refresh-token use.
Discovery	T1087 Account Discovery; T1213 Data from Information Repositories; T1526 Cloud Service Dashboard	Snowflake SHOW TABLES, Salesforce object enumeration, SharePoint/Slack sensitive keyword searches, Okta/M365 discovery.	Query logs, sensitive search-term frequency, admin API enumeration.
Collection	T1213 Data from Information Repositories; T1119 Automated Collection	Salesforce Data Loader exports, Snowflake COPY INTO staging, M365/SharePoint file	Bulk export events, unusual API read volume, temporary stage creation, large object

		access, Slack data targeting.	downloads.
Command and Control	T1090 Proxy	Mullvad VPN, PIA VPN, TOR, VPS infrastructure used for SaaS access and exfiltration.	Anonymizer IP access to SaaS, rare ASN, TOR exit nodes, new geography.
Exfiltration	T1041 Exfiltration Over C2 Channel; T1537 Transfer Data to Cloud Account; T1567 Exfiltration Over Web Service	Salesforce/Snowflake export, MEGA or VPS storage, cloud storage transfers.	Data export volume, GET from Snowflake stages, cloud-to-external transfer, unusual download clients.
Impact	T1657 Financial Theft; T1491 Defacement/Public Leak Pressure	Direct extortion, breach listing, public leak threats, sale of victim data.	Extortion emails, brand impersonation, leak-site monitoring, executive communications.

6. Campaign and Tradecraft Deep Dive

6.1. Snowflake Customer Data-Theft Cluster (UNC5537)

Mandiant reported that UNC5537 systematically compromised Snowflake customer instances with stolen customer credentials. Every investigated incident tied to the campaign traced back to compromised customer credentials rather than a breach of Snowflake's enterprise environment. The campaign succeeded because affected accounts often lacked MFA, historical infostealer credentials remained valid for years, and network allow lists were not configured.

Key Snowflake observations:

Behavior	Details	Detection Opportunity
Infostealer credential reuse	Credentials traced to VIDAR, RISEPRO, REDLINE, Raccoon Stealer, LUMMA, and METASTEALERS; some credential exposure dated back to 2020.	Monitor credential exposure, force rotation, correlate SaaS login with known exposed credentials.
Contractor device exposure	Mandiant observed initial infostealer compromise on contractor systems used for personal activities, gaming, and pirated software.	Enforce managed-device access, contractor identity governance, device compliance for data platforms.
Reconnaissance clients	SnowSight/Snowflake UI, SnowSQL, DBEaver Ultimate, PythonConnector, JDBC, and FROSTBITE/rapeflake.	Alert on unusual client application IDs and first-seen data-warehouse clients.
SQL enumeration	SHOW TABLES, listing stages, user/role/session/organization queries.	Detect broad enumeration by accounts that do not normally administer Snowflake.
Staging and export	CREATE TEMPORARY STAGE, COPY INTO compressed CSV/GZIP, GET to local path.	Detect temporary stages, large COPY INTO jobs, GET commands, abnormal result size.
Infrastructure	Mullvad, Private Internet Access, TOR-like anonymization, ALEXHOST VPS, MEGA and international VPS storage.	Alert on anonymizer/VPS access to data warehouses and cloud storage.

6.2. Salesforce Vishing and OAuth Abuse (UNC6040 / UNC6240)

GTIG tracks a significant portion of the Salesforce intrusion activity as UNC6040. Operators impersonate IT support in voice calls and deceive employees into authorizing a malicious connected application, often a modified or actor-controlled version

of Salesforce Data Loader. The victim enters a connection code or approves the app, granting access that can be used to query and exfiltrate Salesforce data. GTIG reported that the actor initially relied on Salesforce Data Loader and later shifted toward custom Python applications with similar export functionality.

GTIG tracks subsequent extortion as UNC6240, noting that extortion communications sometimes occur months after initial theft and consistently claimed the ShinyHunters name. Reported extortion patterns include calls or emails to victim employees, bitcoin payment demands, 72-hour deadlines, and preparation for public leak pressure.

Key Salesforce observations:

Behavior	Details	Detection Opportunity
Vishing pretext	Actor impersonates IT support or vendor personnel.	Support-ticket correlation, callback verification, sudden MFA/app approval during call windows.
Connected-app authorization	Victim authorizes malicious Data Loader-like OAuth app.	New connected app, suspicious callback URL, low-reputation publisher, high-privilege scopes.
Credential/MFA collection	Okta phishing panel or direct request for credentials/MFA codes during call.	Okta phishing domains, new device enrollment, login from VPN/TOR, repeated MFA events.
Immediate data exfiltration	Data Loader or custom Python script queries/export Salesforce objects.	Bulk API/export events, high-volume API reads, Export Report, unusual object access.
Cross-SaaS lateral movement	Credentials used to access Okta, Microsoft 365, and other cloud platforms.	Cross-platform correlation after Salesforce events.
Delayed extortion	UNC6240 extortion may follow later and claim ShinyHunters.	Preserve logs beyond immediate incident window; monitor extortion emails/domains.

6.3. Expanded SaaS Targeting and Data Discovery

Mandiant's 2026 ShinyHunters-branded reporting describes expansion beyond a single SaaS platform. The activity includes victim-branded credential harvesting, SSO compromise, unauthorized MFA device enrollment, and searching cloud applications for documents containing terms such as poc, confidential, internal, proposal, salesforce, and vpn. Slack data was reportedly targeted or claimed in some victim environments. The pattern indicates an actor that knows the value of internal sales documents, VPN procedures, proposals, proof-of-concept documents, security notifications, and business process artifacts.

Defenders should therefore treat internal search telemetry as a detection surface. A compromised salesperson, contractor, or support user searching broadly for confidential, internal, vpn, password, okta, salesforce, proposal, poc, or security terms across SharePoint/OneDrive/Google Drive/Slack can be a higher-signal indicator than endpoint process telemetry.

7. Infrastructure and Indicators

Indicator / Signal	Type	Operational Use	Confidence
shinycorp@tuta[.]com	Email address	UNC6240 extortion sender address reported by GTIG.	High
shinygroup@tuta[.]com	Email address	UNC6240 extortion sender address reported by GTIG.	High
Data Loader / modified Data Loader connected app	Tool / OAuth app	Salesforce data export via malicious or unauthorized app	High

		authorization.	
Custom Python Data Loader-like scripts	Tooling	Automated Salesforce data collection after vishing.	High
FROSTBITE / rapeflake	Snowflake reconnaissance utility	Snowflake SQL reconnaissance: users, roles, IPs, sessions, organization names.	High
DBeaver_DBeaverUltimate	Client application ID	Observed Snowflake data access client.	High
PythonConnector 3.10.1 / 2.7.6	Client application ID	Observed Snowflake access/exfiltration client family.	High
JDBC 3.13.30 / 3.15.0	Client application ID	Observed Snowflake access client.	High
SnowSQL 1.2.32	Client application ID	Snowflake CLI access.	High
Snowflake UI / SnowSight	Client application ID	Native Snowflake UI access.	High
Mullvad VPN	Infrastructure class	Used for Salesforce/Snowflake access and vishing-era operations.	High
Private Internet Access VPN	Infrastructure class	Observed in Snowflake customer access.	High
TOR	Infrastructure class	Used in evolved UNC6040 collection and anonymity.	High
ALEXHOST SRL AS200019	VPS provider/ASN	Observed for Snowflake exfiltration infrastructure.	High
MEGA	Cloud storage service	Observed as storage for stolen data.	Medium-High
Search terms: poc, confidential, internal, proposal, salesforce, vpn	Discovery terms	Sensitive document discovery in cloud applications.	High

No malware hash list is provided because the most relevant ShinyHunters-branded operations are identity/SaaS abuse patterns. Treat the above as behavioral indicators and analytic pivots, not blocklist-only IOCs.

8. Victimology and Targeting

ShinyHunters-branded operations favor organizations with large, monetizable data stores and reputational sensitivity. The actor is sector-agnostic but data-value selective.

Sector	Why It Is Attractive	Typical Data at Risk
Retail and luxury goods	Customer loyalty data, purchase history, brand sensitivity, high public pressure.	Customer PII, order history, CRM notes, loyalty identifiers.

Aviation and travel	Large customer bases, regulated notification pressure, frequent public attention.	Customer records, loyalty accounts, travel metadata, contact data.
Insurance and finance-adjacent services	PII-rich data, regulatory exposure, extortion leverage.	Customer profiles, claims metadata, contact details, policy data.
Technology and SaaS	Downstream customer exposure, integrations, support/ticket data.	CRM records, customer support notes, integration tokens, product/customer lists.
Education	Broad user populations, legacy applications, potentially exposed PeopleSoft/SaaS stacks.	Student/staff PII, HR records, financial records.
Telecommunications and media/gaming	Large consumer databases and brand sensitivity.	Subscriber data, account information, user records.
Third-party service providers and contractors	Access paths into many customers.	Stored credentials, administrative access, cross-client data.

Geographically, reporting emphasizes multinational and English-speaking branches, but the risk is global because the targeted platforms are global. Any organization with Salesforce, Snowflake, Okta, Microsoft 365, Google Workspace, Slack, cloud storage, and contractor access can be exposed.

9. Detection Engineering

9.1. Detection Summary

Signal	Telemetry Source	Analytic Goal	Priority
New Salesforce connected app with export/API scopes approved by non-admin or unusual user	Salesforce Setup Audit Trail, Event Monitoring, IdP OAuth logs	Detect malicious Data Loader-like app authorization.	Critical
Salesforce high-volume Bulk API or Data Loader export after OAuth approval	Salesforce Event Monitoring / API logs	Detect immediate CRM data theft.	Critical
Snowflake CREATE TEMP STAGE + COPY INTO + GET sequence by unusual user/client	Snowflake ACCOUNT_USAGE query/access history	Detect staged warehouse exfiltration.	Critical
MFA method enrollment/reset followed by risky sign-in from VPN/TOR or unmanaged device	Entra ID / Okta / IdP logs	Detect vishing/help-desk compromise.	Critical
Deletion of security/MFA notification emails	M365 Unified Audit Log / Exchange logs	Detect attacker cleanup or concealment.	High
Sensitive-term searches across SharePoint/OneDrive/Google Drive/Slack	M365, Google Workspace, Slack Enterprise logs	Detect post-compromise discovery.	High
New service account key/API token or OAuth grant used from new ASN/location	Cloud/SaaS audit logs	Detect non-human identity abuse.	High

Extortion sender contact or mail artifacts	Mail gateway / case management	Detect ShinyHunters-branded extortion.	Medium
--	--------------------------------	--	--------

9.2. Sigma: Salesforce Suspicious Connected App Authorization

```

title: Suspicious Salesforce Connected App Authorization Followed By Bulk Access
id: 10c7380b-387f-45c0-9f87-shinyhunters-sf-oauth
status: experimental
description: Detects Salesforce connected-app or OAuth authorization patterns consistent with ShinyHunters/UNC6040-style vishing where a user is convinced to authorize a Data Loader-like application for data export.
references:
  - https://cloud.google.com/blog/topics/threat-intelligence/voice-phishing-data-extortion
  - https://cloud.google.com/blog/topics/threat-intelligence/unc6040-proactive-hardening-
recommendations
author: Lost Boys Cyber
date: 2026/07/30
tags:
  - attack.initial_access
  - attack.t1078
  - attack.persistence
  - attack.t1098
  - attack.exfiltration
logsource:
  product: salesforce
  service: event_monitoring
detection:
  app_name:
    Application|contains:
      - 'Data Loader'
      - 'DataLoader'
      - 'Python'
      - 'bulk'
      - 'export'
  oauth_or_connected_app_event:
    EventType|contains:
      - 'ConnectedApp'
      - 'OAuth'
      - 'RemoteAccess2'
      - 'ApiEvent'
  bulk_access:
    EventType|contains:
      - 'BulkApi'
      - 'RestApi'
      - 'ReportExport'
  condition: oauth_or_connected_app_event and app_name or bulk_access
fields:
  - Timestamp
  - Username
  - EventType
  - Application
  - ClientIp
  - LoginGeo
  - OAuthScopes
falsepositives:
  - Authorized admin-approved integrations and scheduled ETL jobs. Baseline expected connected apps and service accounts before alerting.
level: high

```

9.3. Sigma: Snowflake Temporary Stage Export Sequence

```

title: Snowflake Temporary Stage Data Export Sequence
id: 2b73b7ff-4f42-4147-9b24-shinyhunters-snowflake-export
status: experimental
description: Detects SQL commands associated with UNC5537 Snowflake staging and exfiltration: broad enumeration, temporary stage creation, COPY INTO compressed export, and GET download.

```

```

references:
- https://cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion
author: Lost Boys Cyber
date: 2026/07/30
tags:
- attack.collection
- attack.t1213
- attack.exfiltration
- attack.t1567
logsource:
  product: snowflake
  service: query_history
detection:
  recon:
    QUERY_TEXT|re: '(?i)\bSHOW\s+TABLES\b|\bLIST\s+@\bLS\s+@'
  stage:
    QUERY_TEXT|re: '(?i)\bCREATE\s+(TEMP|TEMPORARY)\s+STAGE\b'
  copy:
    QUERY_TEXT|re: '(?i)\bCOPY\s+INTO\s+@.*\bCOMPRESSION\s*=\s*GZIP'
  get:
    QUERY_TEXT|re: '(?i)\bGET\s+@.*file:/// '
  suspicious_client:
    CLIENT_APPLICATION_ID|contains:
      - 'DBeaver_DBeaverUltimate'
      - 'rapeflake'
      - 'PythonConnector'
      - 'JDBC 3.13.30'
      - 'JDBC 3.15.0'
      - 'SnowSQL 1.2.32'
    condition: stage or copy or get or (recon and suspicious_client)
fields:
- START_TIME
- USER_NAME
- ROLE_NAME
- CLIENT_IP
- CLIENT_APPLICATION_ID
- QUERY_TEXT
- BYTES_WRITTEN_TO_RESULT
falsepositives:
- Legitimate ETL administration. Tune to approved clients, service accounts, warehouses, and network policies.
level: critical

```

9.4. KQL: Entra ID MFA Enrollment or Reset Followed by Risky SaaS Sign-In

```

let lookback = 14d;
let resetWindow = 6h;
let MfaChanges = AuditLogs
| where TimeGenerated > ago(lookback)
| where OperationName has_any ('Add authentication method', 'Update authentication method', 'Delete authentication method', 'Reset password', 'Admin registered security info')
| extend TargetUser = tostring(TargetResources[0].userPrincipalName)
| project MfaTime=TimeGenerated, TargetUser, OperationName, InitiatedBy=tostring(InitiatedBy), CorrelationId;
let RiskySignins = SigninLogs
| where TimeGenerated > ago(lookback)
| where AppDisplayName has_any ('Salesforce', 'Snowflake', 'Okta', 'Office 365', 'Microsoft Office 365', 'Google Workspace') or ResourceDisplayName has_any ('Salesforce', 'Snowflake')
| where RiskLevelDuringSignIn in ('medium', 'high') or ConditionalAccessStatus != 'success' or isempty(DeviceDetail.deviceId) or NetworkLocationDetails has_any ('vpn', 'tor', 'anonymous')
| project SigninTime=TimeGenerated, TargetUser=UserPrincipalName, AppDisplayName, IPAddress, Location, DeviceDetail, RiskLevelDuringSignIn, ConditionalAccessStatus;
MfaChanges
| join kind=inner RiskySignins on TargetUser
| where SigninTime between (MfaTime .. MfaTime + resetWindow)
| project MfaTime, SigninTime, TargetUser, OperationName, AppDisplayName, IPAddress, Location,

```

```
RiskLevelDuringSignIn, ConditionalAccessStatus, DeviceDetail, InitiatedBy, CorrelationId
| order by SignInTime desc
```

9.5. KQL: M365 Sensitive Document Searches After Identity Change

```
let terms =
dynamic(['confidential','internal','proposal','poc','vpn','salesforce','snowflake','password','okta','token','secret','customer export']);
let RecentIdentityChanges = AuditLogs
| where TimeGenerated > ago(14d)
| where OperationName has_any ('Add authentication method','Reset password','Consent to application','Add service principal','Add app role assignment')
| extend User = toString(TargetResources[0].userPrincipalName)
| project ChangeTime=TimeGenerated, User, OperationName;
let Searches = OfficeActivity
| where TimeGenerated > ago(14d)
| where Workload in ('SharePoint','OneDrive','Exchange')
| where Operation has_any ('SearchQueryPerformed','FileAccessed','FileDownloaded')
| extend SearchText=tolower(coalesce(tostring(SearchQueryText), toString(SourceFileName), toString(OfficeObjectId)))
| where SearchText has_any (terms)
| project SearchTime=TimeGenerated, User=UserId, Workload, Operation, SearchText, ClientIP;
RecentIdentityChanges
| join kind=inner Searches on User
| where SearchTime between (ChangeTime .. ChangeTime + 24h)
| summarize SearchTerms=make_set(SearchText, 20), Workloads=make_set(Workload), Ops=make_set(Operation), FirstSearch=min(SearchTime), LastSearch=max(SearchTime), ClientIPs=make_set(ClientIP) by User, OperationName, ChangeTime
| where array_length(SearchTerms) >= 3
```

9.6. KQL: Salesforce Bulk Export Spike Correlated With New OAuth Consent

```
let lookback = 14d;
let OAuthConsent = SalesforceEventLog
| where TimeGenerated > ago(lookback)
| where EventType has_any ('ConnectedApp', 'OAuth', 'RemoteAccess2')
| project ConsentTime=TimeGenerated, Username, ClientIp, Application, OAuthScopes;
let BulkExport = SalesforceEventLog
| where TimeGenerated > ago(lookback)
| where EventType has_any ('BulkApi', 'ReportExport', 'RestApi')
| summarize ExportEvents=count(), Objects=make_set(ObjectName, 50), Bytes=sum(to_long(BytesTransferred))
by Username, bin(TimeGenerated, 1h), ClientIp, Application
| where ExportEvents > 50 or Bytes > 100000000;
OAuthConsent
| join kind=inner BulkExport on Username
| where TimeGenerated between (ConsentTime .. ConsentTime + 8h)
| project ConsentTime, ExportHour=TimeGenerated, Username, ClientIp, Application, OAuthScopes, ExportEvents, Bytes, Objects
| order by ExportHour desc
```

9.7. SPL: Snowflake Exfiltration Commands

```
index=snowflake sourcetype=snowflake:query_history earliest=-30d
| eval q=lower(query_text)
| eval suspicious_client=if(match(client_application_id,"(?i)(dbeaver_dbeaverultimate|rapeflake|pythonconnector|jdbc 3\13\30|jdbc 3\15\0|snowsql 1\2\32)"),1,0)
| eval export_cmd=case(match(q,"create\\s+(temp|temporary)\\s+stage"),"temporary_stage", match(q,"copy\\s+into\\s+@.*compression\\s*=\\s*gzip"),"copy_into_gzip", match(q,"get\\s+@.*file:///"),"get_to_local", match(q,"show\\s+tables|list\\s+@|ls\\s+@"),"recon")
| where isnotnull(export_cmd) OR suspicious_client=1
| stats values(export_cmd) as commands values(client_application_id) as clients values(client_ip) as ips count by user_name role_name warehouse_name span=1h
| where mvcount(commands) >= 2 OR like(q,mvjoin(clients,""),"%DBeaver%") OR like(mvjoin(clients,""),"%rapeflake%")
```

9.8. YARA: Data Loader-Like Python Export Script (Repository / Endpoint Triage)

```
rule LBC_ShinyHunters_DataLoader_Like_Python_Exporter
```

```
{
  meta:
    description = "Hunts for Python scripts with Salesforce Data Loader / Bulk API export behavior consistent with UNC6040-style tooling. Not malware-specific; use for repository and endpoint triage."
    author = "Lost Boys Cyber"
    date = "2026-07-30"
    reference = "https://cloud.google.com/blog/topics/threat-intelligence/voice-phishing-data-extortion"
  strings:
    $sf1 = "salesforce" nocase
    $sf2 = "simple_salesforce" nocase
    $sf3 = "bulk" nocase
    $sf4 = "query_all" nocase
    $sf5 = "/services/oauth2/token" nocase
    $ex1 = "csv.writer" nocase
    $ex2 = "gzip" nocase
    $ex3 = "export" nocase
    $tok1 = "refresh_token" nocase
    $tok2 = "client_secret" nocase
  condition:
    filesize < 2MB and uint16(0) != 0x5a4d and 3 of ($sf*) and 1 of ($ex*) and 1 of ($tok*)
}
```

10. Threat Hunting

10.1. Hunt 1: OAuth Consent to High-Risk SaaS App Followed by Data Access

Hypothesis: A user was coached by phone to approve a malicious connected app or OAuth grant, and that app immediately accessed CRM or SaaS data at abnormal volume.

```
let lookback=30d;
let NewConsents = AuditLogs
| where TimeGenerated > ago(lookback)
| where OperationName has_any ('Consent to application','Add service principal','Add app role assignment grant to user','Add delegated permission grant')
| extend AppName=tostring(TargetResources[0].displayName),
User=tostring(InitiatedBy.user.userPrincipalName), ActorIp=tostring(InitiatedBy.user.ipAddress)
| where AppName has_any ('Data Loader','loader','export','bulk','sync','crm') or
tostring(TargetResources) has_any ('offline_access','full','api','refresh_token')
| project ConsentTime=TimeGenerated, User, ActorIp, AppName, OperationName, TargetResources;
let SaaSAccess = CloudAppEvents
| where TimeGenerated > ago(lookback)
| where Application has_any ('Salesforce','Snowflake','Microsoft 365','Google Workspace')
| where ActionType has_any ('FileDownloaded','Export','BulkApi','Query','ReportExport','DataExport')
| summarize Events=count(), Apps=make_set(Application), Actions=make_set(ActionType),
IPs=make_set(IPAddress), First=min(TimeGenerated), Last=max(TimeGenerated) by AccountDisplayName;
NewConsents
| join kind=leftouter SaaSAccess on $left.User == $right.AccountDisplayName
| where First between (ConsentTime .. ConsentTime + 12h) or isnoteempty(TargetResources)
| order by ConsentTime desc
```

10.2. Hunt 2: Snowflake Data Staging and Exfiltration Sequence

Hypothesis: A compromised Snowflake user created a temporary stage, copied large tables into compressed files, and downloaded them using GET from a new client/IP.

```
SELECT
  user_name,
  role_name,
  client_ip,
  client_application_id,
  COUNT(*) AS query_count,
  MIN(start_time) AS first_seen,
  MAX(start_time) AS last_seen,
  LISTAGG(DISTINCT CASE
    WHEN REGEXP_LIKE(query_text, 'CREATE\\s+(TEMP|TEMPORARY)\\s+STAGE', 'i') THEN 'CREATE_TEMP_STAGE'
```



```

    WHEN REGEXP_LIKE(query_text, 'COPY\\s+INTO\\s+', 'i') THEN 'COPY_INTO_STAGE'
    WHEN REGEXP_LIKE(query_text, 'GET\\s+@.*file:/// ', 'i') THEN 'GET_TO_LOCAL'
    WHEN REGEXP_LIKE(query_text, 'SHOW\\s+TABLES|LIST\\s+@|LS\\s+', 'i') THEN 'RECON'
END, ',') AS observed_behaviors
FROM snowflake.account_usage.query_history
WHERE start_time >= DATEADD(day, -30, CURRENT_TIMESTAMP())
AND (
    REGEXP_LIKE(query_text, 'CREATE\\s+(TEMP|TEMPORARY)\\s+STAGE|COPY\\s+INTO\\s+@|GET\\s+@.*file:///|
SHOW\\s+TABLES|LIST\\s+@|LS\\s+', 'i')
    OR REGEXP_LIKE(client_application_id, 'DBever DBeverUltimate|rapeflake|PythonConnector|JDBC 3\\
\\.13\\.30|JDBC 3\\.15\\.0|SnowSQL 1\\.2\\.32', 'i')
)
GROUP BY user_name, role_name, client_ip, client_application_id
HAVING query_count >= 3 OR observed_behaviors LIKE '%COPY_INTO_STAGE%' OR observed_behaviors LIKE
'%GET_TO_LOCAL%'
ORDER BY last_seen DESC;

```

10.3. Hunt 3: Help-Desk Reset Pattern Across Multiple Users

Hypothesis: A social engineer convinced support personnel to reset MFA or enroll devices for one or more users, followed by logins from unfamiliar infrastructure.

```

let window=24h;
let ResetEvents = AuditLogs
| where TimeGenerated > ago(14d)
| where OperationName has_any ('Reset password','Add authentication method','Admin registered security
info','Update user','Update authentication method')
| extend Admin=tostring(InitiatedBy.user.userPrincipalName),
Target=tostring(TargetResources[0].userPrincipalName)
| summarize Targets=make_set(Target), ResetCount=count(), FirstReset=min(TimeGenerated),
LastReset=max(TimeGenerated) by Admin, bin(TimeGenerated, window);
let NewInfraLogins = SigninLogs
| where TimeGenerated > ago(14d)
| where isempty(DeviceDetail.deviceId) or AppDisplayName has_any
('Salesforce','Snowflake','Okta','Microsoft Office 365')
| summarize LoginIPs=make_set(IPAddress), Apps=make_set(AppDisplayName), FirstLogin=min(TimeGenerated),
LastLogin=max(TimeGenerated) by UserPrincipalName;
ResetEvents
| mv-expand Target=Targets
| join kind=inner NewInfraLogins on $left.Target == $right.UserPrincipalName
| where FirstLogin between (FirstReset .. LastReset + 12h)
| where ResetCount >= 2 or array_length(LoginIPs) >= 2
| project Admin, Target, ResetCount, FirstReset, LastReset, FirstLogin, LastLogin, LoginIPs, Apps

```

10.4. Hunt 4: Deletion of MFA and Security Notification Emails

Hypothesis: After enrolling a new MFA method or authorizing an application, the actor deletes user-facing notification emails to slow discovery.

```

OfficeActivity
| where TimeGenerated > ago(30d)
| where Workload == 'Exchange'
| where Operation in ('SoftDelete','HardDelete','MoveToDeletedItems','New-InboxRule','Set-InboxRule')
| extend Subject=tolower(tostring(Subject)), Params=tolower(tostring(Parameters))
| where Subject has_any ('mfa','multi-factor','security method','factor enrolled','new sign-in','app
consent','oauth','connected app','2-step','2fa')
    or Params has_any ('mfa','security method','app consent','oauth','connected app')
| summarize Count=count(), Subjects=make_set(Subject, 20), Operations=make_set(Operation),
First=min(TimeGenerated), Last=max(TimeGenerated), ClientIPs=make_set(ClientIP) by UserId
| where Count >= 2

```

10.5. Hunt 5: Sensitive-Term Searches in Collaboration Platforms

Hypothesis: A compromised SaaS identity is searching for high-value internal documents and access procedures using terms observed in ShinyHunters-branded SaaS data theft reporting.

```

let sensitive_terms = dynamic(['poc','proof of

```

```
concept', 'confidential', 'internal', 'proposal', 'salesforce', 'snowflake', 'vpn', 'okta', 'password', 'secret',
'token', 'customer list', 'export']));
CloudAppEvents
| where TimeGenerated > ago(30d)
| where Application has_any ('Microsoft SharePoint Online', 'OneDrive for Business', 'Google
Drive', 'Slack', 'Microsoft Teams')
| where ActionType has_any ('Search', 'FileDownloaded', 'FileAccessed', 'Export', 'MessageSearched')
| extend SearchOrObject=tolower(strcat(RawEventData.SearchQueryText, ' ', ObjectName, ' ',
tostring(RawEventData.query), ' ', tostring(RawEventData.file_name)))
| where SearchOrObject has_any (sensitive_terms)
| summarize TermsOrObjects=make_set(SearchOrObject, 30), Actions=make_set(ActionType),
Apps=make_set(Application), IPs=make_set(IPAddress), First=min(TimeGenerated), Last=max(TimeGenerated),
EventCount=count() by AccountDisplayName
| where EventCount >= 5 or array_length(Apps) >= 2
| order by EventCount desc
```

11. Risk Assessment

Risk Dimension	Assessment	Rationale
Likelihood	High for organizations with exposed SaaS credentials, weak MFA, unmanaged contractor access, permissive OAuth app consent, or limited SaaS logging.	The actor relies on common enterprise control gaps rather than rare exploits.
Impact	High where CRM/data warehouse exports include customer PII, regulated data, confidential proposals, or downstream customer data.	Data theft can trigger notification, regulatory, legal, reputational, and fraud consequences.
Detectability	Medium without SaaS logs; High if IdP, Salesforce, Snowflake, M365, Google Workspace, Slack, and cloud audit logs are centralized.	The behavior is visible in control-plane telemetry, but many environments lack retention or correlation.
Control Maturity Needed	Identity-first and SaaS-first.	Endpoint-only controls will miss many relevant behaviors.
Time Pressure	High during extortion.	UNC6240-style extortion reporting includes 72-hour payment pressure and possible delayed contact months after theft.

Highest-risk organizations are those that cannot quickly answer these questions:

- Which users and service accounts can export Salesforce objects or Snowflake tables?
- Are all data-warehouse and CRM accounts protected by phishing-resistant MFA?
- Can users approve OAuth/connected apps without admin review?
- Are contractor devices managed and compliant before data-platform access?
- Are Snowflake network policies/allow lists enforced for privileged accounts?
- Can security teams detect temporary stages, COPY INTO, GET, and bulk CRM exports?
- Are MFA enrollment and app-consent events correlated with subsequent SaaS activity?
- Are SaaS logs retained long enough to investigate delayed extortion months after access?

12. Recommendations

Priority	Owner	Action	Why It Matters
Critical	Identity / IAM	Enforce phishing-resistant MFA for administrators, data-platform users, CRM admins,	Reduces vishing, SIM-swap, and credential-reuse impact.

		help-desk staff, and executives. Remove SMS/voice/email fallback for privileged users.	
Critical	SaaS Platform Owners	Require admin approval for Salesforce connected apps and high-risk OAuth scopes. Maintain an allowlist of approved integrations and alert on new apps.	Directly addresses UNC6040 Data Loader-style app authorization.
Critical	Data Platform Owners	Enforce Snowflake MFA, network policies, session policies, and least privilege. Disable dormant users and rotate credentials exposed in infostealer logs.	Directly addresses UNC5537 root causes.
Critical	SOC / Detection Engineering	Centralize Salesforce, Snowflake, IdP, M365/Google Workspace, Slack, and cloud audit logs with at least 180-365 days retention.	Delayed extortion requires historical reconstruction.
High	Help Desk / IT Operations	Implement high-assurance identity verification for password resets, MFA resets, and device enrollment: live video, manager callback, known-good phone callback, and no reliance on public PII.	Counters vishing and help-desk impersonation.
High	Cloud Security	Inventory service accounts, OAuth grants, API keys, non-human identities, and third-party integrations; restrict by IP/device/context where possible.	ShinyHunters-branded reporting emphasizes non-human identity risk.
High	SOC	Deploy detections in this package and tune against known ETL jobs, support workflows, and sanctioned SaaS integrations.	Provides behavior coverage before incident pressure begins.
High	Legal / Privacy / Comms	Pre-stage data extortion response playbooks, customer-notification decision trees, regulator contacts, and public-claim validation procedures.	Extortion windows can be short and public.
Medium	Procurement / Vendor Risk	Add SaaS integration and support-call verification controls to third-party risk reviews.	Actors may impersonate vendors or abuse trusted integration workflows.
Medium	Awareness / Red Team	Run controlled vishing/tabletop exercises against help-desk and	Validates process controls

		SaaS app-approval workflows under written rules of engagement.	safely before adversaries do.
--	--	--	-------------------------------

13. Incident Response Playbook Addendum

If ShinyHunters-branded activity is suspected, prioritize containment over endpoint imaging unless malware is present. Recommended first 24-hour actions:

1. Revoke active sessions and refresh tokens for suspected identities across IdP, Salesforce, Snowflake, M365/Google Workspace, Slack, VPN/VDI, and cloud consoles.
2. Disable or restrict self-service password reset and MFA registration for high-risk populations.
3. Freeze new Salesforce connected-app approvals and review all recently approved apps, OAuth grants, callback URLs, publishers, and scopes.
4. Query Snowflake for CREATE TEMP STAGE, COPY INTO, GET, unusual clients, unusual IPs, and large result sets over the full available retention window.
5. Pull support-desk tickets and call logs for password reset, MFA reset, device enrollment, and vendor-support requests involving affected users.
6. Preserve SaaS audit logs immediately. Do not assume default retention will be enough.
7. Review M365/Google/Slack search and download activity for sensitive terms and bulk exports.
8. Search mail logs for extortion sender addresses, suspicious Tuta/Proton/webmail contact, and deleted security notifications.
9. Prepare a data impact matrix: data source, object/table/file, user, export time, row/file count, affected individuals/customers, regulatory category.
10. Monitor breach forums, Telegram references, and data-leak claims, but do not treat public actor claims as validated until matched to internal telemetry.

14. References

- [1] Google Cloud / Mandiant, "UNC5537 Targets Snowflake Customer Instances for Data Theft and Extortion," June 10, 2024. <https://cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion>
- [2] Google Cloud / GTIG, "The Cost of a Call: From Voice Phishing to Data Extortion," June 4, 2025. <https://cloud.google.com/blog/topics/threat-intelligence/voice-phishing-data-extortion>
- [3] Google Cloud / GTIG, "Cybercrime Observations from the Frontlines: UNC6040 Proactive Hardening Recommendations," September 30, 2025. <https://cloud.google.com/blog/topics/threat-intelligence/unc6040-proactive-hardening-recommendations>
- [4] Google Cloud / Mandiant, "Guidance from the Frontlines: Proactive Defense Against ShinyHunters-Branded Data Theft Targeting SaaS," January 30, 2026. <https://cloud.google.com/blog/topics/threat-intelligence/defense-against-shinyhunters-cybercrime-saas>
- [5] Google Cloud / Mandiant, "Tracking the Expansion of ShinyHunters-Branded SaaS Data Theft," January 31, 2026. <https://cloud.google.com/blog/topics/threat-intelligence/expansion-shinyhunters-saas-data-theft>
- [6] Google Cloud / Mandiant, "Hello, Operator? A Technical Analysis of Vishing Threats," June 4, 2025. <https://cloud.google.com/blog/topics/threat-intelligence/technical-analysis-vishing-threats>
- [7] Salesforce Security Guidance, "Protect Salesforce environments from social engineering and malicious connected apps." <https://help.salesforce.com/>
- [8] Snowflake Security Guidance, "Hardening Snowflake customer environments and threat hunting guidance." <https://www.snowflake.com/en/resources/learn/security/>
- [9] CISA, "Scattered Spider," Cybersecurity Advisory AA23-320A. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a>

- [10] Sophos, "Taking the shine off BreachForums," June 26, 2025. <https://www.sophos.com/en-us/blog/taking-the-shine-off-breachforums>
- [11] KrebsOnSecurity, "ShinyHunters Wage Broad Corporate Extortion Spree," October 7, 2025. <https://krebsonsecurity.com/2025/10/shinyhunters-wage-broad-corporate-extortion-spree/>
- [12] BleepingComputer, "ShinyHunters behind Salesforce data theft attacks at Qantas, Allianz Life, and LVMH," August 1, 2025. <https://www.bleepingcomputer.com/news/security/shinyhunters-behind-salesforce-data-theft-attacks-at-qantas-allianz-life-and-lvmh/>